

Security incident report

Section 1: Identify the network protocol involved in the incident

The primary network protocol identified in the tcpdump packet captures is **TCP (Transmission Control Protocol)**. The traffic shows TCP connection establishment using SYN, SYN-ACK, and ACK packets. The packet capture also contains **DNS** traffic for resolving domain names and **HTTP** traffic for communication with the web servers over port 80.

Section 2: Document the incident

The website yummyrecipesforme.com was compromised after a former employee conducted a **brute force attack** against the website's administrative account. The attacker repeatedly attempted known default passwords until successfully guessing the administrator password. The administrator account was still using its default password, and there were no controls in place to limit or prevent repeated login attempts.

After gaining administrative access, the attacker accessed the website's admin panel and modified the website's source code. The attacker inserted JavaScript that prompted visitors to download and run an executable file while visiting the website.

The downloaded executable contained a script that redirected users from yummyrecipesforme.com to a fraudulent website, greatrecipesforme.com, which contained malware. The attacker also changed the administrative account password after compromising the account, preventing the website owner from logging in.

The incident was discovered after several customers contacted the company's helpdesk. Customers reported that the website prompted them to download a file to access free recipes. After running the file, their browsers were redirected

to a different website and their computers began operating more slowly.

Cybersecurity analysts investigated the incident in a controlled sandbox environment using `tcpdump` to capture and analyze network traffic.

The packet capture showed the following sequence:

1. The user's computer sent a **DNS request** for `yummyrecipesforme.com`.
2. The DNS server returned the IP address `203.0.113.22`.
3. The user's computer established a **TCP connection** with `yummyrecipesforme.com` on HTTP port 80.
4. The browser sent an HTTP `GET / HTTP/1.1` request to the website.
5. The malicious website prompted the user to download an executable file.
6. After the file was executed, the computer sent another DNS request for `greatrecipesforme.com`.
7. The DNS server returned the IP address `192.0.2.17`.
8. The user's computer established a new TCP connection with `greatrecipesforme.com` over HTTP port 80.
9. The browser sent an HTTP request to the fraudulent website.

The website source-code investigation confirmed that malicious JavaScript had been added to the legitimate website. Analysis of the downloaded executable confirmed that it contained a script that redirected visitors to `greatrecipesforme.com`.

The available evidence indicates that the initial compromise occurred through a **brute force attack against the administrative account**, followed by unauthorized modification of the website source code and distribution of malware to website visitors.

Sources of evidence included customer reports, the website's source code, analysis of the downloaded executable, and the `tcpdump` network traffic logs.

Section 3: Recommend one remediation for brute force attacks

Implement login-attempt limits and account lockout controls.

The organization should limit the number of unsuccessful login attempts allowed for the administrative account. For example, the system could temporarily lock the account or introduce an increasing delay after several failed login attempts.

This measure would make a brute force attack significantly more difficult because an attacker would not be able to continuously try different passwords. It would also generate an opportunity for security personnel to detect and investigate repeated failed login attempts.

The organization should also ensure that the default administrative password is changed to a strong, unique password. However, for this incident report, limiting login attempts is the recommended primary control because it directly addresses the brute force technique used by the attacker.